

Week 2 Practical Laboratory

Developing Security Policies and Procedures

NexusTech Solutions — Policy Overhaul Simulation

Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Week	Week 2: 12–18 September 2026
Delivery	5 Days • Self-Paced • Intermediate
Opens	12 September 2026, 8:00 AM WAT
Due	18 September 2026, 11:59 PM WAT

Table of Contents

1. Introduction
2. Task 1 – Security Policy Hierarchy
3. Task 2 – Acceptable Use Policy
4. Task 3 – User Access Request Procedure
5. Task 4 – Policy Implementation and Communication
6. Task 5 – Policy Review and Maintenance
7. Conclusion
8. References

1. Introduction

NexusTech Solutions is a growing software development company that has expanded from 50 to 250 employees and now serves clients in the financial and healthcare sectors. The organisation currently relies on an outdated “IT Rules” document that combines policies, technical instructions and recommendations. This has resulted in inconsistent practices, unclear accountability and compliance gaps.

This report develops a structured security policy framework for NexusTech using the Security Policy Development Lifecycle. It covers the policy hierarchy, Acceptable Use Policy, User Access Request Procedure, policy communication and training, and policy review and maintenance. The aim is to create practical and maintainable security governance that supports the organisation's growth and security objectives.

2. Task 1 – Security Policy Hierarchy

2.1 Policy Hierarchy Definitions

1. Policy Hierarchy Definitions

Document	Purpose	Authority	Mandatory or Recommended	Level of Detail
Policy	Defines the organisation's overall security requirements and direction.	High	Mandatory	High-level
Standard	Defines specific requirements that must be met to support a policy.	High	Mandatory	More specific
Procedure	Provides step-by-step instructions for carrying out a requirement.	Operational	Mandatory where applicable	Detailed
Guideline	Provides recommended practices to help users meet security objectives.	Advisory	Recommended	General guidance

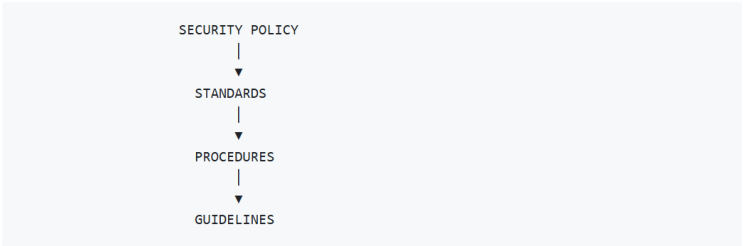
2.2 Statement Categorisation

2. Statement Categorisation

#	Statement	Classification	Justification
1	All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.	Policy	It establishes a mandatory security requirement for employees.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It provides step-by-step instructions for configuring MFA.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	It recommends a security practice rather than making it mandatory.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	It states a high-level organisational security commitment.
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	It defines a specific mandatory technical requirement.
6	Employees should avoid connecting to public, unsecured	Guideline	It provides recommended behaviour rather than a

2.3 Policy Hierarchy Diagram

NexusTech Security Policy Hierarchy



Explanation

The policy hierarchy helps NexusTech separate high-level security requirements from the detailed instructions used to implement them. Policies establish what the organisation requires, standards define specific mandatory requirements, procedures explain how activities are carried out and guidelines provide recommended practices.

Task 2 – Acceptable Use Policy

1 Background

NexusTech Solutions did not have formal rules governing the use of company devices and corporate networks. Unauthorised software downloads and excessive personal use had increased the risk of malware, security incidents and compliance issues.

To address this gap, an Acceptable Use Policy (AUP) was developed to clearly define acceptable and prohibited use of NexusTech technology resources.

2 Policy Details

Item	Details
Policy Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approved By	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Scope	Employees, contractors, consultants, interns and authorised users

3 Key Policy Requirements

The AUP establishes requirements covering:

- **Acceptable use** – Users must use company technology responsibly and for authorised purposes.
- **Prohibited activities** – Users must not install unauthorised software, bypass security controls, share credentials, access information without authorisation or use unauthorised cloud storage for confidential information.
- **Personal use** – Limited personal use is permitted where it does not interfere with work or create security, legal or compliance risks.

- **Security responsibilities** – Users must protect accounts, devices and company information and report suspected security incidents.
- **Management responsibilities** – Managers are responsible for ensuring their teams understand and follow the policy.
- **IT and Information Security responsibilities** – These teams maintain security controls, support users, investigate incidents and provide security awareness.
- **HR responsibilities** – HR supports communication, acknowledgement and enforcement of the policy.

4 Compliance and Enforcement

All users within the scope of the policy are required to comply with the AUP. Violations may result in appropriate disciplinary or access-related action depending on the nature and severity of the violation.

Exceptions must be formally requested, justified and approved by the Information Security Manager and the appropriate business owner.

5 Policy Acknowledgement and Review

All users are required to acknowledge that they have read, understood and agreed to comply with the AUP.

The policy will be reviewed annually and may also be reviewed earlier following significant technology or business changes, changes in security risks or a security incident.

6 Evidence

The complete Acceptable Use Policy is maintained in the project GitHub repository under:

<https://github.com/rebeccakalende/GRC102-NexusTech-Lab/blob/main/Task-2-Acceptable-Use-Policy/01-Acceptable-Use-Policy.md>

Task 3 – User Access Request Procedure.

1. Background

NexusTech Solutions previously relied on informal email and chat requests for user access. This created a risk of inconsistent permissions and unauthorised access.

A formal User Access Request Procedure was therefore developed to ensure that access is properly requested, approved, provisioned and documented.

2. Procedure Overview

The procedure establishes the following access management process:

Access Request → Verification → Approval → Provisioning → Notification → Evidence Capture → Ticket Closure → Periodic Review

3. Key Requirements

Area	Requirement
Request	All access requests must be submitted through the approved IT service desk workflow.
Approval	Manager and, where required, system/data owner approval must be obtained.
Verification	IT must verify the user's identity, role and business need.
Least Privilege	Users receive only the permissions required for their duties.
Provisioning	Approved access is created or modified by authorised IT personnel.
Notification	The user and relevant manager are informed when access is granted.
Evidence	Requests, approvals and provisioning details are recorded in the ticket.
Emergency Access	Emergency access requires justification, documentation and subsequent review.
Audit Trail	Access records are retained for security reviews and audits.
Access Review	Permissions are periodically reviewed and unnecessary access removed.

4. Roles and Responsibilities

The procedure defines responsibilities for:

- **IT Helpdesk/IT Team:** Processing requests, verifying approvals, provisioning access and maintaining records.
- **Managers:** Confirming business need and approving access.
- **System/Data Owners:** Approving access to systems and sensitive information.
- **Information Security:** Providing security oversight and monitoring compliance.
- **Users:** Requesting appropriate access and protecting their accounts.

5. Evidence

The complete procedure is maintained in the GitHub repository under:

<https://github.com/rebeccakalende/GRC102-NexusTech-Lab/tree/main/Task-3-Access-Request-Procedure>

Task 4 – Communication and Training Plan

The plan ensures employees understand and adopt the new Acceptable Use Policy and User Access Request Procedure.

It covers:

- **Target audiences:** Employees, IT staff and management.
- **Communication channels:** Email, all-hands meetings, intranet, training and team briefings.
- **Rollout:** Announcement → policy distribution → training → acknowledgement → follow-up → effectiveness review.
- **Acknowledgement:** Users confirm they have read, understood and agreed to follow the policies.
- **Measuring effectiveness:** Training completion, policy acknowledgement, access-request compliance and reduction in repeated misunderstandings/incidents.
- **Non-compliance:** Follow-up by managers, with repeated issues escalated to Information Security and HR.
- **Evidence:** The full plan is saved in GitHub under Task-4-Communication-and-Training.

Task 5 – Policy Review and Maintenance Memo.

1. Review Triggers

The policy review was triggered by two major events:

- Migration of the primary database to **AWS**.
- A security incident involving an employee sharing sensitive information through personal cloud storage.

These events indicate that the existing policies need to be reviewed against the current technology environment and risks.

2. Review Process

The review will involve:

1. Consulting relevant stakeholders.
2. Assessing risks arising from the AWS migration and security incident.
3. Reviewing evidence such as incidents, access records, training records and audit findings.
4. Identifying gaps and updating the relevant policies.

3. Recommended Policy Updates

The Acceptable Use Policy should be updated to:

- Clearly prohibit storing or sharing confidential information through personal cloud storage unless authorised.
- Clarify requirements for using approved cloud services, including AWS-related systems.
- Strengthen requirements for securely sharing sensitive information.

4. Ownership and Review

The **Information Security Manager** remains responsible for maintaining the policies. Significant changes should go through stakeholder review and the appropriate approval process, with CEO approval where required.

Policies should be reviewed **at least annually**, with an earlier review triggered by major technology changes, significant security incidents, compliance changes or major security risks.

5. Evidence

The complete memo is maintained in GitHub under:

<https://github.com/rebeccakalende/GRC102-NexusTech-Lab/tree/main/Task-5-Policy-Review-Memo>

Conclusion

The GRC102 practical laboratory established a structured security policy framework for NexusTech Solutions.

The work addressed the organisation's previous mixture of policies, technical instructions and recommendations by clearly separating policies, standards, procedures and guidelines.

The developed Acceptable Use Policy establishes clear expectations for the use of company technology and information. The User Access Request Procedure provides a controlled approach to requesting, approving and provisioning access. The Communication and Training Plan supports adoption of these requirements, while the Policy Review and Maintenance Memo establish a process for keeping the framework current as the organisation and its risks change.

Together, the five evidence bundles provide a structured foundation for improving security governance, accountability and policy maintenance at NexusTech Solutions.

References

1. NexusTech Solutions GRC102 Practical Laboratory – Security Policy Framework and Governance.
2. NexusTech Solutions Evidence Bundle 1 – Security Policy Hierarchy.
3. NexusTech Solutions Evidence Bundle 2 – Acceptable Use Policy.
4. NexusTech Solutions Evidence Bundle 3 – User Access Request Procedure.

5. NexusTech Solutions Evidence Bundle 4 – Communication and Training Plan.
6. NexusTech Solutions Evidence Bundle 5 – Policy Review and Maintenance Memo.